

[LOGOTIPO DA EMPRESA]	NOME DA EMPRESA		
	DOCUMENTO CORPORATIVO		
Título: POLÍTICA DE SEGURANÇA DA INFORMAÇÃO			
Código: POL-SEG-001	Classificação: Uso Interno	Área Responsável: Tecnologia da Informação / Segurança da Informação	
Data de Emissão: 07/06/2026	Versão: 1.0	Status: Vigente	Página: Página 1 de 1

1. OBJETIVO

Esta Política estabelece as diretrizes de Segurança da Informação da empresa, visando proteger os ativos de informação contra acessos não autorizados, divulgação indevida, alteração, perda, destruição ou indisponibilidade, garantindo a continuidade dos negócios, a conformidade legal e a proteção dos dados pessoais tratados pela organização.

2. ABRANGÊNCIA

Esta Política aplica-se integralmente a:

- I. Empregados;
- II. Estagiários;
- III. Aprendizes;
- IV. Prestadores de serviços;
- V. Terceiros;
- VI. Parceiros comerciais;
- VII. Fornecedores que possuam acesso aos ativos de informação da empresa.

3. PRINCÍPIOS DA SEGURANÇA DA INFORMAÇÃO

A proteção das informações observará rigorosamente os seguintes princípios pilares:

- Confidencialidade;
- Integridade;
- Disponibilidade;
- Autenticidade;
- Rastreabilidade;
- Conformidade legal.

4. ATIVOS DE INFORMAÇÃO

Para efeitos desta política, são considerados ativos de informação pertencentes à empresa:

- Dados corporativos;
- Dados pessoais;
- Sistemas informatizados;
- Correio eletrônico corporativo;
- Documentos físicos e digitais;
- Equipamentos de TI;
- Serviços em nuvem;
- Credenciais de acesso;
- Bases de dados;
- Registros de auditoria.

5. CLASSIFICAÇÃO DA INFORMAÇÃO

As informações institucionais deverão ser devidamente classificadas conforme seu nível de sensibilidade e criticidade:

5.1 Pública

Informação cuja divulgação pública e irrestrita não gera impactos ou riscos à empresa.

5.2 Uso Interno

Informação destinada exclusivamente ao ambiente corporativo e ao conhecimento dos colaboradores e parceiros autorizados.

5.3 Confidencial

Informação cujo acesso deve ser estritamente restrito a grupos ou indivíduos específicos para finalidades de negócio demarcadas.

5.4 Restrita

Informação altamente crítica cujo vazamento ou divulgação não autorizada pode causar severos prejuízos financeiros, legais, operacionais ou reputacionais à organização.

6. CONTROLE DE ACESSO

6.1 O acesso às informações e sistemas eletrônicos deverá observar estritamente o princípio do menor privilégio.

6.2 Os usuários receberão apenas e tão somente os perfis de acessos estritamente necessários ao desempenho de suas atribuições profissionais regulares.

6.3 É terminantemente proibido aos usuários:

- I. Compartilhar senhas corporativas;
- II. Utilizar credenciais ou contas de terceiros;
- III. Contornar ou tentar violar mecanismos e barreiras de segurança implementadas;
- IV. Manter ou explorar privilégios de acessos não autorizados.

6.4 Todos os acessos e requisições a sistemas poderão ser registrados eletronicamente para fins de controle e auditoria técnica.

7. SENHAS E AUTENTICAÇÃO

7.1 As credenciais de acesso corporativas são estritamente pessoais e intransferíveis.

7.2 Sempre que for tecnicamente possível e disponível, deverá ser obrigatoriamente utilizada a autenticação multifator (MFA) nos ambientes da empresa.

7.3 As senhas não deverão sob nenhuma hipótese ser compartilhadas, anotadas em locais físicos visíveis ou armazenadas em arquivos eletrônicos de forma insegura.

8. USO DO CORREIO ELETRÔNICO CORPORATIVO

8.1 O correio eletrônico corporativo constitui uma ferramenta de trabalho legítima pertencente exclusivamente à empresa.

8.2 Todo o conteúdo profissional gerado ou armazenado na conta corporativa é considerado ativo estrito da organização.

8.3 A empresa reserva-se o direito de realizar monitoramento, auditoria, retenção, backup e acesso às informações contidas nas contas corporativas sempre que necessário para:

- Continuidade operacional e administrativa;
- Atendimento regular a demandas de clientes;
- Condução de investigações internas de segurança;
- Realização de auditorias preventivas ou corretivas;
- Cumprimento cabível de obrigações legais ou regulatórias;
- Proteção dos interesses legítimos e integridade da empresa.

8.4 O usuário não deverá fazer uso da conta corporativa para fins de armazenamento de conteúdos de cunho estritamente pessoal.

9. DISPOSITIVOS CORPORATIVOS

9.1 Equipamentos computacionais corporativos destinam-se prioritariamente às atividades de cunho profissional.

9.2 A empresa poderá adotar ferramentas centrais de gerenciamento para monitoramento, inventariado automatizado e aplicação de proteção nos dispositivos móveis e estações de trabalho.

9.3 É expressamente vedada a instalação ou execução de softwares não homologados e não autorizados previamente pela TI.

10. MONITORAMENTO E AUDITORIA

10.1 A empresa poderá registrar e monitorar ativamente as atividades realizadas em todos os seus ativos tecnológicos e canais de comunicação.

10.2 Os registros coletados incluirão:

- Logs de acessos a sistemas e arquivos;
- Logs de autenticação e tentativas de login;
- Registros operacionais de sistemas e servidores;
- Eventos de segurança computacional;
- Trilhas abrangentes de auditoria eletrônica.

10.3 As rotinas de monitoramento técnico serão executadas observando-se os preceitos de necessidade, finalidade específica, proporcionalidade e adequação com os riscos do negócio.

11. PROTEÇÃO DE DADOS PESSOAIS

11.1 Todo e qualquer tratamento de dados pessoais realizado no ecossistema da empresa observará os mandamentos da Lei Geral de Proteção de Dados (Lei nº 13.709/2018 - LGPD).

11.2 Os dados pessoais deverão ser tratados estritamente para finalidades legítimas, explícitas e totalmente compatíveis com o escopo de atuação e bases legais da organização.

11.3 O acesso aos ambientes que contenham dados pessoais será restrito aos profissionais que demonstrem real necessidade de manuseio dessas informações para a execução de suas respectivas funções.

12. INCIDENTES DE SEGURANÇA

12.1 Todo usuário tem o dever de comunicar imediatamente à equipe de segurança qualquer incidente de segurança identificado, potencial ou suspeito.

12.2 Enquadram-se como exemplos práticos de incidentes de segurança:

- Vazamento ou exposição indevida de informações corporativas;
- Acesso lógico não autorizado a sistemas;
- Infecção ou presença de códigos maliciosos (Malware);
- Perda, furto ou roubo de equipamentos tecnológicos;
- Compartilhamento inadequado de bases de dados pessoais ou sigilosas.

12.3 A organização manterá e atualizará um procedimento específico para resposta rápida e tratamento de incidentes de segurança cibernética.

13. DESLIGAMENTO DE COLABORADORES

13.1 Em cenários de desligamento, todos os acessos lógicos e físicos do colaborador deverão ser prontamente revogados, em consonância direta com os procedimentos internos operacionais.

13.2 A empresa poderá reter e acessar as informações e históricos de negócios nas contas para garantir a perenidade operacional, a preservação de direitos em litígios ou obrigações regulatórias.

13.3 O rito técnico e as regras de consulta pós-desligamento deverão obedecer imperativamente aos termos fixados no *Procedimento de Gestão de Contas Corporativas e Desligamento*.

14. RESPONSABILIDADES

14.1 Todos os usuários integrados ao ambiente corporativo são pessoalmente responsáveis pela proteção ativa das informações às quais tenham acesso legitimamente.

14.2 Os gestores de área têm o dever de revisar e garantir que as permissões de acesso da sua equipe mantenham-se estritamente compatíveis com as funções corporativas executadas.

14.3 A área de Tecnologia da Informação implementará os controles técnicos protetivos necessários e condizentes com os níveis de riscos mapeados.

14.4 O Encarregado de Proteção de Dados (DPO), em conjunto com as áreas de Compliance e Jurídico, prestará o apoio estratégico para assegurar a conformidade regulatória contínua ligada à privacidade.

15. SANÇÕES

O descumprimento deliberado ou negligente das normas estipuladas nesta Política poderá resultar na aplicação rigorosa de sanções disciplinares, administrativas, rescisões contratuais, além das responsabilizações nas esferas civis e criminais cabíveis.

16. TREINAMENTO E CONSCIENTIZAÇÃO

Todos os usuários integrados à infraestrutura corporativa deverão obrigatoriamente participar das ações de conscientização, palestras e treinamentos periódicos promovidos pela empresa acerca de Segurança da Informação e Proteção de Dados Pessoais.

17. REVISÃO

Esta Política de Segurança da Informação será revisada periodicamente sempre que ocorrerem mudanças significativas nos processos organizacionais, no ecossistema regulatório, no cenário de ameaças tecnológicas ou, no máximo, a cada 24 (vinte e quatro) meses.

18. APROVAÇÃO

Esta Política entra em vigor na data de sua homologação e aprovação formal por parte da Diretoria Executiva, sendo de observância obrigatória por todos os indivíduos que utilizem os recursos tecnológicos corporativos.